

Kịch bản demo Phân hệ 2 — chia cho 5 người

Bảo mật dữ liệu y tế trên Oracle (CSC12001 — ATBM HTTT)

Kịch bản bám theo DEMO_SCRIPT.md + TALKING_POINTS.md, bao trùm TC#1, YC1–YC4 và **phần mở rộng** (mã hóa đường truyền NNE, mã hóa cột TDE, masking, đổi mật khẩu).

Thông điệp xuyên suốt (mọi người nhắc lại)

Ranh giới bảo mật thật nằm ở **Database Engine** (RBAC + VPD + OLS + Audit). Ứng dụng WinForms là tầng phòng thủ bổ sung (defense-in-depth) + **mã hóa** (NNE trên đường truyền, TDE at-rest). Tức là đồ án có đủ cả **Access Control lẫn Cryptography**.

Phân công tổng quan

STT	Người	Phản phụ trách	Tài khoản chính	Thời lượng
1	A	Dẫn nhập + Kiến trúc + Phân hệ 1 (DBA) + TC#1 + Đổi mật khẩu	SYSTEM / HOSPITAL_DBA	4'
2	B	YC1 – RBAC: Kỹ thuật viên + Bệnh nhân (view + trigger)	KTV_NV006, BN_BN001	4'
3	C	YC1 – VPD: Điều phối viên + Bác sĩ	DPV_NV001, BS_NV003	5'
4	D	YC2 – OLS + YC3 – Audit	u4_nvtk_hcm, DBA	5'
5	E	YC4 – Backup/Recovery + Mã hóa (NNE + TDE) + Kết luận	BVADMIN, DBA	6'

Tài khoản dùng chung: mật khẩu nhân viên/bệnh nhân = BV@2025!; OLS u4_nvtk_hcm = U4@2025; DBA = SYSTEM/oracle hoặc HOSPITAL_DBA/Hospital@DBA2025; SYS = <mật_khẩu_SYS> (tự điền).

CHECKLIST chuẩn bị (làm TRƯỚC buổi demo)

- ☐ DB đang chạy, đã chạy migration 01→12 + setup_all (xem run_migrations.ps1 / scripts/setup.ps1).
- ☐ \$env:NLS_LANG = ".AL32UTF8" ở MỌI cửa sổ PowerShell/sqlplus (tránh hòng tiếng Việt).
- ☐ Đã chạy 13_TDE_Encryption.sql + keystore **OPEN** (kiểm: SELECT STATUS FROM V\$ENCRYPTION_WALLET;).
- ☐ Đã bật **Native Network Encryption** trong sqlnet.ora (xem docs/guides/SETUP_ENCRYPTION.md).
- ☐ Build app: dotnet run --project HospitalApp (đóng bản cũ trước).
- ☐ Mở sẵn 2 cửa sổ: **HospitalApp** + **SQL*Plus/SQL Developer** (để chạy query DBA).
- ☐ Dữ liệu mẫu nguyên vẹn (SELECT COUNT(*) FROM BVADMIN.HSBA_DV; = 5).
- ☐ Đăng nhập thử trước 5 tài khoản để chắc không kẹt mật khẩu.

NGƯỜI 1 (A) — Dẫn nhập + Kiến trúc + Phân hệ 1 + TC#1 + Đổi mật khẩu

Nói: giới thiệu bài toán (bệnh viện đa cơ sở, dữ liệu nhạy cảm), nêu **thông điệp xuyên suốt** ở trên.

Demo:

1. **Phân hệ 1 – AdminDashboard** (SYSTEM/oracle hoặc HOSPITAL_DBA/Hospital@DBA2025): tạo user demo TEST_USER, tạo role, **grant/revoke** role + object/system privilege; xem lại **system / object / role privileges**.
2. **TC#1 – ánh xạ tài khoản**: mỗi người dùng app = **một Oracle account** riêng (cột ORACLE_USER trong NHANVIEN/BENHNHAN) → VPD/OLS tự áp theo SESSION_USER. Đăng xuất, đăng nhập 2 vai trò khác nhau để thấy giao diện đổi theo role.
3. **Đổi mật khẩu (self-service)**: ở bất kỳ form nào bấm **“Đổi mật khẩu”** → nhập cũ/mới → *“Vui lòng đăng nhập lại”* → đăng nhập bằng mật khẩu mới. **Nói**: dùng ALTER USER ... IDENTIFIED BY ... REPLACE ... — user tự đổi mật khẩu của chính mình **không cần quyền DBA**.

Có thể bị hỏi: *“Brute-force tăng app khác gì DB profile?”* → App khóa sớm (5 lần sai/60s) trước khi gửi kết nối lỗi xuống DB; DB profile là lớp chặn cuối.

NGƯỜI 2 (B) — YC1 RBAC: Kỹ thuật viên + Bệnh nhân

Nói: KTV và BN dùng **view + trigger** (RBAC) vì chỉ cần lọc theo 1 cột & giới hạn cột sửa.

Demo KTV (KTV_NV006/BV@2025!):

1. View KTV_HSBA_DV_View chỉ trả dịch vụ có MAKTV = NV006 (không thấy của KTV khác).
2. Cập nhật cột **KẾT QUẢ** → lưu thành công.
3. (SQL*Plus) thử UPDATE cột khác (vd LOAIDV) → trigger chặn **ORA-20001** (KTV chỉ được sửa KẾT QUẢ).

Demo Bệnh nhân (BN_BN001/BV@2025!):

1. Chỉ xem được **thông tin của chính mình** (view BN_BENHNHAN_View lọc theo ORACLE_USER).
2. Sửa **địa chỉ / tiền sử bệnh** hợp lệ → lưu OK.
3. Thử sửa CCCD → INSTEAD OF trigger chặn **ORA-20002** (không được đổi định danh).
4. Chỉ ra CCCD đang mask 4 số cuối (•••••5678) — data minimization.

Có thể bị hỏi: *“Vì sao KTV dùng RBAC/view thay VPD?”* → KTV chỉ lọc theo MAKTV; view + trigger là đủ, dễ kiểm soát cột update, dễ minh họa.

NGƯỜI 3 (C) — YC1 VPD: Điều phối viên + Bác sĩ

Nói: DPV/BS truy cập **cùng** các bảng HSBA/HSBA_DV/DONTHUOC nên dùng **VPD** — Oracle tự chèn WHERE predicate vào MỌI câu SQL, an toàn kể cả truy vấn trực tiếp (không bypass được).

Demo Điều phối viên (DPV_NV001/BV@2025!):

1. **Thêm bệnh nhân mới** → app gọi sp_create_benhnhan_full: **tự sinh MÃBN + tự tạo tài khoản** BN_<MABN> (TC#1). Báo lại mã + tài khoản đăng nhập.
2. Tạo **HSBA** (mã sinh bằng sequence fn_next_mahsba), **gán bác sĩ + gán KTV** cho dịch vụ.
3. Tab **Thông tin của tôi**: sửa quê quán / SDT.
4. Ô CCCD: mặc định mask, bấm **nút con mắt (con mắt)** để lộ đầy đủ khi đối chiếu (chỉ DPV mới có).

Demo Bác sĩ (BS_NV003/BV@2025!):

1. **VPD trên HSBA**: chỉ thấy hồ sơ có MABS = NV003 (không thấy của BS khác).
2. Cập nhật **chẩn đoán/điều trị/kết luận** → trigger ghi LOG_BS_HSBA (giá trị cũ/mới).

3. Thêm **dịch vụ chặn đoán**, chọn KTV bằng dropdown; thêm/sửa **đơn thuốc** → **FGA + trigger** ghi vết.
4. (tùy) cập nhật tiền sử/dị ứng của BN mình điều trị (TC#3d) — cột column-grant.

Có thể bị hỏi: “*update_check=>TRUE để làm gì?*” → sau update, Oracle kiểm lại policy, chặn việc sửa khóa-lọc để đẩy dữ liệu sang phạm vi khác. (Lưu ý: bài này để FALSE để tránh ORA-28138 khi INSERT qua INSTEAD OF — giải thích được nếu bị hỏi.)

NGƯỜI 4 (D) — YC2 OLS + YC3 Audit

Demo OLS (u4_nvtk_hcm/U4@2025):

1. Mở **OLSViewerForm**, nhấn người dùng = **NV:HCM:TK**.
2. Chỉ thấy thông báo có nhãn **phù hợp**, không thấy thông báo cấp cao hơn.
3. (đối chứng) đăng nhập u1_giamdoc (cấp **BGD**) → thấy nhiều thông báo hơn.
4. **Nói:** chính sách BV_LABEL_POLICY = level NV < LDK < BGD + **compartment** HCM/HPN/HNI + **group** TH/TK/TM.

Demo Audit (DBA / SQL*Plus):

```
SELECT USERNAME, ACTION_NAME, OBJ_NAME, TIMESTAMP
FROM DBA_AUDIT_TRAIL ORDER BY TIMESTAMP DESC FETCH FIRST 20 ROWS ONLY;

SELECT DB_USER, OBJECT_NAME, POLICY_NAME, SQL_TEXT, EXTENDED_TIMESTAMP
FROM DBA_FGA_AUDIT_TRAIL ORDER BY EXTENDED_TIMESTAMP DESC FETCH FIRST 20 ROWS ONLY;
```

- Chỉ ra dòng audit ứng với thao tác Người 3 vừa làm (sửa chặn đoán, thêm đơn thuốc).
- Mở bảng log nghiệp vụ: LOG_BS_HSBA, LOG_BS_DONTHUOC, LOG_KTV_KETQUA.

Có thể bị hỏi: “*compartment vs group khác gì?*” → compartment nghĩa **AND** (phải có đủ); group nghĩa **OR** và có **phân cấp**.

NGƯỜI 5 (E) — YC4 Backup/Recovery + Mã hóa (NNE + TDE) + Kết luận

Demo YC4 – Flashback recovery (chính, trực quan):

```
$env:NLS_LANG = ".AL32UTF8"
sqlplus /nolog "@d:\repos\Oracle\PhanHe2\extras\recovery_demo.sql"
```

- Chỉ ra 3 mốc: HSBA_DV = **5** → xóa nhầm HS001 còn **4** → **FLASHBACK TABLE** về **5** ✓.
- **Nói** so sánh 3 phương pháp (xem 07_YC4_Backup_Recovery.sql phần D): **RMAN** (vật lý, toàn vẹn cao) · **Data Pump** (logic, di động) · **Flashback** (phục hồi cực nhanh lỗi người dùng). RMAN/Data Pump cho xem lệnh + log; Flashback demo trực tiếp.

Demo mã hóa đường truyền (NNE):

```
SELECT NETWORK_SERVICE_BANNER
FROM V$SESSION_CONNECT_INFO
WHERE SID = SYS_CONTEXT('USERENV', 'SID');
```

Chỉ ra dòng có **AES256 + SHA** → kết nối TCP đã mã hóa (cấu hình sqlnet.ora, ENCRYPTION_SERVER=REQUIRED).

Demo mã hóa cột at-rest (TDE):

```
SELECT TABLE_NAME, COLUMN_NAME, ENCRYPTION_ALG  
FROM DBA_ENCRYPTED_COLUMNS ORDER BY TABLE_NAME, COLUMN_NAME;
```

CCCD, CMND (NO SALT → giữ UNIQUE), DIUNGTHUOC (có salt) — AES. App vẫn đọc plaintext (giải mã trong suốt); trên đĩa là ciphertext.

Kết luận: đồ án phủ **Access Control** (RBAC + VPD + OLS) + **Audit** + **Backup/Recovery** + **Cryptography** (NNE đường truyền, TDE at-rest, masking) — bảo vệ dữ liệu y tế nhạy cảm nhiều tầng.

Có thể bị hỏi: “*Vì sao cần Oracle Net encryption khi đã có RBAC/VPD?*” → RBAC/VPD/OLS bảo vệ **bên trong** database; NNE bảo vệ dữ liệu **trên đường truyền** TCP (chống bắt gói). “*TDE có chặn DPV xem CCCD không?*” → KHÔNG — TDE trong suốt với phiên hợp lệ; chặn xem là việc của access control/masking.

Luồng thời gian gợi ý (khoảng 24 phút + Q&A)

A (4') → B (4') → C (5') → D (5') → E (6'). Mỗi người tự kết nối tài khoản của mình; chuẩn bị sẵn cửa sổ để chuyển mượt. Nếu thiếu thời gian: rút gọn phần RMAN/Data Pump của E (chỉ nói, không chạy), giữ Flashback + TDE + NNE.